TASK: 12

Subdomain Takeover

&

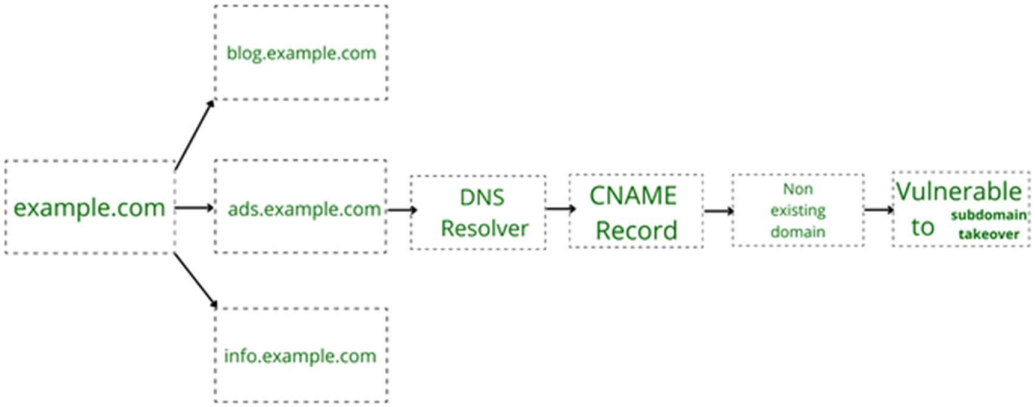
Broken Links Hijacking

Surendra Gabbani

(Subdomain Takeover)

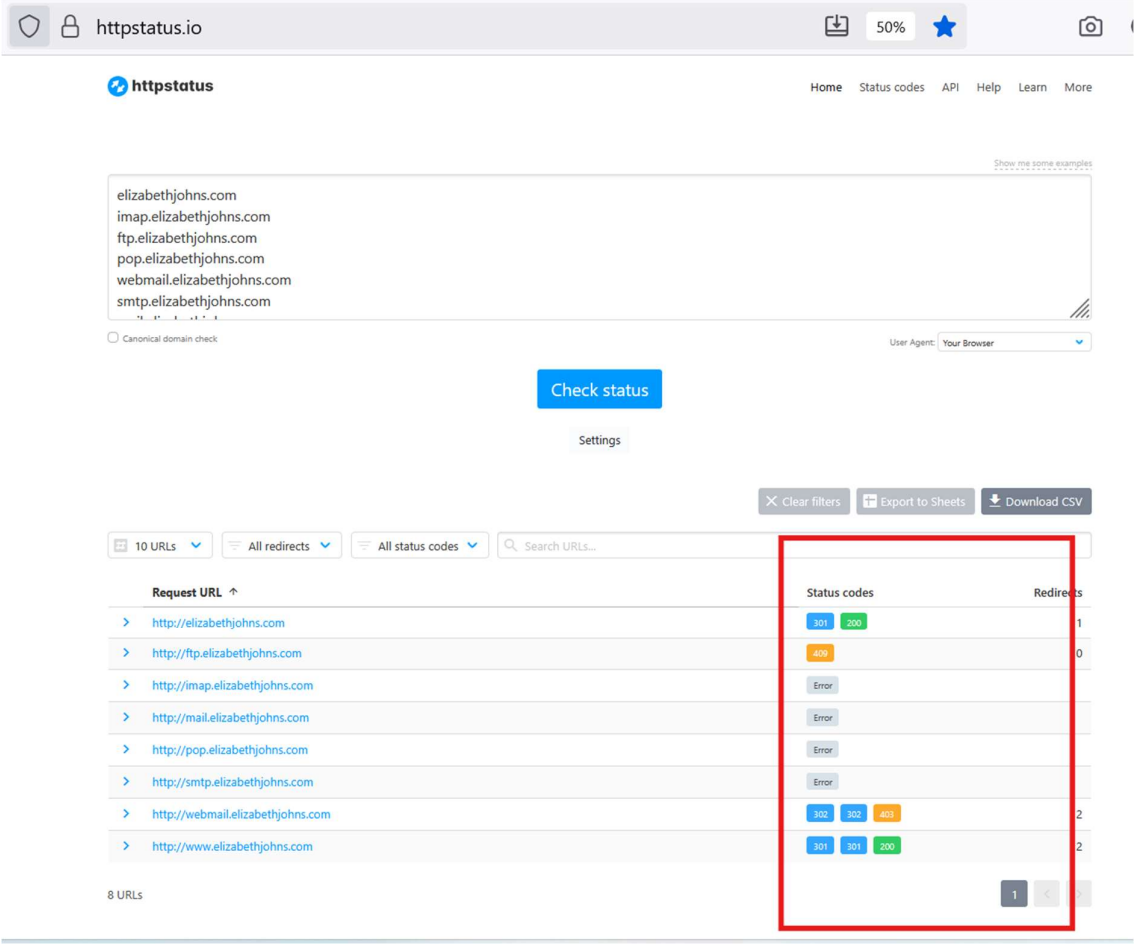
What is a subdomain takeover?

A subdomain takeover happens when a DNS record (usually a CNAME) points a subdomain (e.g. dev.example.com) to an external service (GitHub Pages, Heroku, S3, Azure, etc.) that no longer has a corresponding resource. The DNS still resolves, but no owner controls the target — an attacker could claim the orphaned resource and serve content from that subdomain



- **Ran Subfinder on Kali Linux with this command to find subdomains:**

- **To check the httpstatus code of subdomains**



Common causes & targets:

- Forgotten DNS records after migrations or decommissions
- Deleted tenant resources on GitHub Pages, Heroku, Netlify, AWS S3, Azure, Fastly, Firebase
- Manual DNS edits without cleaning provider resources
- Long-lived DNS records with no owner tracking

Detection & prevention:

- Periodic automated scans (internal or serverless) to detect dangling DNS records.
- Integrate checks into CI/CD when DNS or hosting changes.
- Use provider-specific protections (e.g., “custom domain” ownership checks, reserved hostnames, or automatic cleanup workflows).

(Broken Links Hijacking)

What is BLH?

Broken Link Hijacking (BLH) is a web security issue that happens when attackers take advantage of links (usually in websites, applications, or documentation) that point to external resources which are no longer active or under the control of the original owner

How Broken Link Hijacking Works?

Identify Broken Links

- Links pointing to expired domains, deleted GitHub repositories, abandoned cloud storage buckets, etc.

Take Over the Resource

- Attacker registers the expired domain, creates a repo with the same name, or claims the abandoned cloud resource.

Exploit the Trust

- Since the original website/app still points to that resource, users trust it.
- Attacker can host malware, phishing pages, or inject malicious scripts.

Example Scenarios:

- Expired Domain
  A company's website links to docs.company-support.com, but the domain expires. An attacker buys the domain and hosts phishing content.
- GitHub Repository
  Documentation points to github.com/company/old-repo, which was deleted. An attacker creates a repo with the same name and uploads malicious code or scripts.

How to Find Broken Links ?

- Use automated link-checkers (site crawlers)
- Scan for external references in code, docs, README, and CMS
- Search for 404s and DNS failures in logs and analytics
- Use GitHub / package-manager searches for deleted repos/packages referenced

Prevention (Best Practices):

1. **Regularly Audit Links**
    - Use tools to detect broken or expired links in your code, docs, and websites.
2. **Avoid Linking to Third-Party Uncontrolled Resources**
    - Where possible, self-host critical assets.
3. **Renew & Monitor Domains**
    - Never let important domains expire.
4. **Use Dependency Management Carefully**
    - Verify open-source repos you depend on are still maintained.
5. **Remove or Replace Dead Links Immediately**

Conclusion:

Broken Link Hijacking is a silent but serious security risk where attackers exploit abandoned domains, repositories, or cloud resources that are still referenced by trusted websites. This can lead to phishing, malware delivery, and supply-chain attacks. To mitigate the threat, organizations must regularly audit links, monitor domain expirations, self-host critical assets, and apply strong controls like Content Security Policy (CSP) and Subresource Integrity (SRI). Preventive monitoring and fast remediation are key to protecting users and preserving trust.